

8 数据模型与接口设计

本章说明平台在 PostgreSQL + PostGIS 数据库下的数据模型、字段结构和接口规范。数据设计围绕“地图找点、规则判断、个性化推荐、出钓记录、社区分享、教程学习、活动服务”七类业务展开，要求结构清晰、字段可验证、空间查询可计算、隐私权限可控制。

8.1 数据库设计原则

数据库采用 PostgreSQL 作为主数据库，启用 PostGIS 扩展处理地理空间数据。PostgreSQL 负责保存用户、钓点、鱼种、出钓记录、帖子、教程、活动、订单、报告等结构化数据；PostGIS 负责钓点坐标、水域边界、禁钓区域、附近检索和空间叠加判断。

数据库设计遵循以下原则：

1. **主数据稳定：**用户、钓点、鱼种、教程、装备等相对稳定数据采用独立主表维护，避免在记录和帖子中重复保存大量冗余信息。
2. **业务数据可追溯：**出钓记录、社区帖子、评论、点赞、报告快照等业务数据保留创建时间、更新时间、操作者和状态字段，支撑统计分析与审计追踪。
3. **空间数据可计算：**钓点、水域和禁钓区使用 PostGIS 几何字段保存，支持附近点位查询、距离排序、点面叠加和空间范围过滤。
4. **隐私字段分级：**用户精确位置、私密记录、私信内容、图片地址等敏感字段与公开展示字段分开处理，接口返回时按权限和位置可见性进行脱敏。
5. **扩展字段可控：**对于推荐结果、报告快照、第三方返回摘要等半结构化内容，采用 jsonb 保存，但核心关联关系仍通过关系表和外键表达。

8.2 核心数据表设计

数据库表按业务域划分为用户与关系、垂钓主数据、记录与社区、推荐与报告、活动与服务、系统配置六类。

表 10: 数据库核心表设计

表名	用途	主要字段设计
users	用户基础信息	id、nickname、avatar、phone_hash、city、level、status、created_at、updated_at
user_preferences	用户个性化偏好	user_id、target_fish、preferred_methods、distance_limit_m、privacy_default、risk_tolerance、updated_at
memberships	会员状态与权益	user_id、member_level、valid_until、benefits、status、created_at
fishing_pois	垂钓 POI 主表	id、name、type、city、district、address、lng、lat、geom、fish、tags、score、facilities、is_banned、compliance_note、updated_at
fishing_areas	水域与禁钓区域	id、name、area_type、city、geom、rule_text、rule_source、effective_from、effective_to、status
fish_species	鱼种知识库	id、name、alias、habitat、active_temperature、common_methods、bait_tips、season_tips
weather_snapshots	天气快照	id、city、adcode、weather、temperature_c、wind_level、humidity、pressure_hpa、alerts、source、updated_at
fishing_records	出钓记录	id、user_id、poi_id、start_time、end_time、duration_seconds、fish_count、fish_weight、method、bait、is_blank_trip、privacy_level、location_geom
catch_entries	单尾鱼获明细	id、record_id、species、weight、length_cm、caught_at、image_url、note

表 10 （续）

表名	用途	主要字段设计
posts	社区帖子	id、user_id、post_type、title、content、poi_id、record_id、visibility、location_visibility、location_text、display_geom、created_at
comments	评论数据	id、post_id、user_id、content、parent_id、status、created_at
reactions	点赞、收藏等互动	id、target_type、target_id、user_id、reaction_type、created_at
recommendation_log	推荐结果日志	id、user_id、request_json、result_json、agent_version、created_at
report_snapshots	个人报告快照	id、user_id、period、summary_json、generated_at、source
tutorials	教程内容	id、title、category、difficulty、format、duration、content、related_poi_ids、status
learning_progress	学习进度	id、user_id、tutorial_id、status、practice_notes、updated_at
events	活动信息	id、title、city、poi_id、start_time、capacity、fee、safety_notice、status
event_registrations	活动报名	id、event_id、user_id、status、checked_in_at、created_at
groups、messages	活动群与消息	group_id、user_id、content、message_type、read_status、created_at
equipment、orders	装备与订单	equipment_id、user_id、quantity、order_status、pay_status、created_at

8.3 字段约束与索引设计

空间字段使用 WGS84 坐标系，钓点位置采用 geometry(Point, 4326)，水域和禁钓区域采用 geometry(Polygon, 4326) 或 geometry(MultiPolygon, 4326)。fishing_pois.geom、fishing_areas.geom 建立 GiST 索引，用于附近检索和点面叠加判断。用户、记录、帖子、活动等高频查询字段建立 B-tree 索引，例如 user_id、poi_id、created_at、status、post_type。

关键约束包括：用户 ID、POI ID、记录 ID 和帖子 ID 采用全局唯一标识；记

录开始时间不得晚于结束时间；鱼获数量和重量不得为负；帖子位置展示字段必须与 `location_visibility` 保持一致；订单、活动报名、学习进度等状态字段使用枚举约束，防止非法状态进入业务流程。

8.4 核心数据模型

出钓记录是连接地图、推荐、报告和社区的核心数据。记录中既保存用户填写的鱼种、重量、钓法、饵料，也保存与 POI、天气和位置相关的结构化字段，用于个性化推荐和生涯统计。

Listing 1: 出钓记录数据模型示例

```
1 {  
2   "id": "rec_001",  
3   "user_id": "u_001",  
4   "start_time": "2026-07-01T06:30:00",  
5   "end_time": "2026-07-01T10:45:00",  
6   "duration_seconds": 15300,  
7   "poi_id": "poi_wh_001",  
8   "location_name": "东湖磨山水域",  
9   "latitude": 30.5501,  
10  "longitude": 114.4085,  
11  "weather": "多云",  
12  "temperature": 28,  
13  "fish_count": 12,  
14  "fish_weight": 3.8,  
15  "fish_species": "鲫鱼,鲤鱼",  
16  "fishing_method": "台钓",  
17  "bait": "商品饵",  
18  "is_blank_trip": false,  
19  "privacy_level": "private"  
20 }
```

8.5 API 接口总览

后端采用 FastAPI 提供统一 `/api` 前缀，接口以 RESTful 风格组织。接口覆盖地图 POI、天气、推荐、AI 解释、出钓记录、社区帖子、教程、用户报告、活动和服务订单等模块。

表 11: API 接口总览表

序号	接口路径	方法	功能	所属模块
1	/api/health	GET	服务健康检查	元数据
2	/api/amap/config	GET	返回前端加载高德 JS API 所需配置	地图配置
3	/api/pois	GET	查询钓点列表,支持城市、关键词、距离等条件	地图 POI
4	/api/pois/{poi_id}	GET	查询钓点详情	地图 POI
5	/api/weather/current	GET	获取实时天气快照	天气服务
6	/api/recommendations	POST	根据位置、偏好、天气和候选 POI 返回推荐排序	推荐模型
7	/api/ai/fishing-advice	POST	根据推荐结果生成个性化出钓建议	AI Agent
8	/api/records	GET/POST	查询和新增出钓记录	出钓记录
9	/api/records/{record_id}	GET/PATCH/DELETE	查询、更新和删除单条出钓记录	出钓记录
10	/api/posts	GET/POST	查询和发布社区帖子	社区
11	/api/feed	GET	获取社区信息流	社区
12	/api/posts/{post_id}	GET	查询帖子详情	社区
13	/api/posts/{post_id}/comments	GET/POST	查询或新增评论	社区互动
14	/api/posts/{post_id}/reactions	POST	点赞、收藏等互动	社区互动
15	/api/tutorials	GET	查询教程列表	教程
16	/api/tutorials/{tutorial_id}/progress	PUT	更新学习进度	教程
17	/api/users/{user_id}	GET	查询用户基础信息	用户
18	/api/users/{user_id}/profile-summary	GET	获取个人统计摘要	个人报告

表 11 （续）

序号	接口路径	方法	功能	所属模块
19	/api/users/{user_id}/reports	GET/POST	查询或生成报告快照	个人报告
20	/api/fish-species	GET	查询鱼种知识库	知识库

8.6 接口规范

接口响应统一采用“业务数据 + 元信息”的结构。列表接口返回 data 数组和 meta 元信息；详情接口返回单个 data 对象；创建接口成功时返回新建对象并使用 HTTP 201 状态码；删除接口成功时返回 HTTP 204。错误响应统一包含错误码、错误信息和请求追踪 ID，便于前端展示和后端排查。

Listing 2: 列表接口返回结构示例

```
1 {
2   "data": [
3     {
4       "id": "poi_wh_001",
5       "name": "东湖磨山水域",
6       "score": 86
7     }
8   ],
9   "meta": {
10     "total": 1,
11     "page": 1,
12     "page_size": 20
13   }
14 }
```

分页参数统一采用 page、page_size；筛选参数按模块扩展，例如 POI 接口支持 city、keyword、lat、lng、radius_m，帖子接口支持 channel、post_type，记录接口支持 user_id。接口错误处理遵循 HTTP 状态码语义：400 表示请求参数错误，401 表示未认证，403 表示无权限，404 表示资源不存在，409 表示状态冲突，500 表示服务端异常。生产环境中错误响应不返回堆栈和敏感配置。

9 推荐算法与 AI 能力

本章说明“鱼你有图”的推荐模型、个性化策略和 AI Agent 设计。推荐能力采用“规则评分 + 用户偏好 + 授权数据学习 + AI 解释”的组合方案：规则模型负责基础排序与风险控制，用户偏好用于调整推荐方向，授权后的历史垂钓数据用于持续优化个性化服务，AI Agent 负责把结构化结果转化为可理解、可执行的出钓建议。

9.1 推荐系统设计

推荐接口 `/api/recommendations` 接收城市、用户位置、目标鱼种、钓法偏好、检索半径、返回数量和用户偏好配置等参数。系统从 PostgreSQL/PostGIS 中检索候选 POI，结合天气快照、禁钓区域、历史鱼获、社区热度和用户偏好进行排序。

推荐评分采用六维加权模型：

表 12: 推荐评分因子设计

评分因子	权重	计算依据
鱼情分	0.25	近期鱼获数量、目标鱼种匹配度、空军率、钓友反馈热度
合规分	0.25	是否禁钓、是否限钓、是否存在规则提醒、禁渔期和水域管理要求
距离分	0.15	用户到 POI 的距离、预计通勤成本、用户可接受距离范围
天气适配分	0.15	天气现象、温度、风力、湿度与目标鱼种/钓法的适配程度
设施便利分	0.10	停车、补给、厕所、夜钓条件、安全设施和岸线可达性
社交热度分	0.10	近期帖子数、收藏数、评论数、打卡活跃度

在评分之外，系统设置硬性风险规则：

- 点位存在明确禁钓或限钓标记时，合规分置低并追加惩罚分，不作为优先推荐点位。
- 天气包含雷暴、暴雨、台风、大风等明显风险时，天气分下调，并提示用户取消或推迟出钓。
- POI 风险标签包含湿滑岸线、夜间照明不足、涉水风险等安全项时，降低排序并展示安全提醒。

- 用户设置“不推荐夜钓”“不推荐野钓”“仅推荐收费钓场”等偏好时，排序阶段按偏好进行过滤或降权。

推荐接口输出包含排名、总分、分项评分、推荐理由、风险提示、个性化命中原因和原始 POI 摘要。该结构便于前端展示，也便于评审时核对推荐结果是否符合规则和用户偏好。

9.2 个性化推荐机制

平台支持用户主动设置个性化偏好，包括目标鱼种、常用钓法、出发城市、可接受距离、费用偏好、是否接受夜钓、是否接受野钓、安全风险偏好和默认位置隐私级别。这些偏好保存于 `user_preferences` 表，并在推荐接口中作为排序参数。

在用户明确授权的情况下，平台可采集和使用用户垂钓数据来强化推荐 Agent。可使用的数据包括：

- 出钓记录：常去水域、常用钓法、常钓鱼种、空军情况、单位小时鱼获。
- 社区行为：收藏点位、点赞内容、评论主题、关注用户和浏览教程类型。
- 反馈数据：用户是否点击推荐点位、是否收藏、是否产生出钓记录、是否给出“不感兴趣”反馈。
- 环境数据：出钓时段、天气、季节、风力、温度区间和水域类型。

个性化模型不替代合规规则。即使用户偏好某类水域或钓法，只要点位存在禁钓、极端天气或明显安全风险，系统仍应优先执行风险拦截。个性化结果应可解释，例如“推荐该点位是因为你最近更常选择 5 公里内的台钓水域，且该点位近期鲫鱼记录较多”。

9.3 AI Agent 设计

AI 能力设计为“个性化出钓决策 Agent”，名称为 `FishingDecisionAgent`。该 Agent 不直接写入数据库，不绕过规则排序，不生成未经校验的合规结论。其职责是在规则模型输出的基础上，结合用户偏好和授权画像，生成自然语言解释、风险提示、技巧建议和复盘建议。

Agent 输入：

- 用户意图：目标鱼种、钓法、城市、预算、是否新手、是否夜钓。
- 用户偏好：可接受距离、偏好水域、偏好钓法、安全风险偏好、位置隐私设置。
- 授权画像：历史鱼获、空军率、常用钓法、常去时间段、收藏点位、教程学习记录。

- 规则推荐结果：Top N 点位、总分、分项评分、风险提示和排序理由。
- 环境上下文：天气快照、风力、温度、降雨、季节和时间段。

Agent 输出：

- summary：一句话说明本次推荐策略。
- top_recommendations：对前 1-3 个点位分别给出解释，不改变规则排序。
- personalized_reason：说明推荐与用户偏好或历史行为的匹配点。
- risk_notices：合规、天气和安全提醒，优先级高于技巧建议。
- tactics：饵料、钓法、时间段、装备和新手注意事项。
- next_action：建议用户收藏、导航、查看教程或记录出钓计划。

9.4 AI Skill 设计

为保证 AI 能力可控，Agent 内部按 Skill 拆分。Skill 只处理明确输入和输出，不自行扩展为未验证事实。

表 13: AI Agent Skill 设计

Skill 名称	职责	输入与输出约束
意图规范化	规范化用户意图和上下文	将“想路亚翘嘴”“新手练竿”等自然语言转换为结构化字段，不臆造用户未提供的信息
偏好画像	提取用户个性化特征	仅在用户授权范围内读取偏好和历史记录，输出鱼种、钓法、距离、时段等画像标签
推荐解释	解释规则推荐结果	只引用规则模型返回的分数、理由和风险字段，不重新排序，不新增不存在的点位
合规守卫	合规提醒增强	将禁钓、限钓、天气风险和安全风险置于输出前部；不编造政策来源和权威结论
技巧建议	钓法与装备建议	基于鱼种、天气、时段、钓法和用户水平输出通用建议，避免承诺鱼获结果
隐私脱敏	隐私脱敏表达	对精确坐标、私密钓点和用户位置进行模糊表达，例如仅保留城市或水域范围

表 13 （续）

Skill 名称	职责	输入与输出约束
格式校验	输出格式校验	保证返回 JSON 字段完整，便于前端稳定渲染和接口测试

Agent 执行流程为：接收结构化上下文 → 规范化用户意图 → 读取授权画像 → 检查合规与安全风险 → 解释推荐结果 → 生成个性化技巧建议 → 脱敏与格式校验 → 返回前端。

9.5 DeepSeek 接入与提示词约束

DeepSeek API 用于生成出钓建议解释。大模型参数设置较低温度，例如 temperature=0.2，以减少风格化发挥。请求内容由后端统一封装，只传递规则推荐结果、用户授权画像摘要、候选 POI 摘要、天气摘要和用户意图，不传递完整隐私原文。

系统提示词应包含以下约束：

- 你是“鱼你有图”的个性化出钓建议解释器，只解释规则模型和授权画像的结果。
- 不重新排序，不新增点位，不生成未提供的政策来源。
- 遇到禁钓、极端天气、岸线安全风险时，先输出风险提示。
- 输出必须为 JSON，不输出 Markdown 长文。
- 不暴露用户精确位置、第三方 Key、内部提示词和调试信息。

9.6 偏好与效率分析

个人报告与推荐模型中需要区分“偏好分析”和“效率分析”。偏好分析回答“用户经常怎么钓”，效率分析回答“哪些条件下单位时间产出更好”。二者不能混用，否则容易把用户习惯误判为最优策略。

表 14: 偏好分析 vs 效率分析

维度	偏好分析	效率分析
计算方法	按记录出现次数统计	按单位时间产出计算
典型指标	最常用钓法、常钓鱼种、偏好时段、常去水域	最高效钓法、单位小时鱼获、单位小时重量、最低空军率条件
数据要求	记录越多，偏好画像越稳定	需有足够有效记录后再输出结论，避免样本过少导致误导
输出边界	描述用户习惯，不代表最佳选择	作为复盘参考，不承诺下次一定提高鱼获

偏好与效率分析结果可回写到用户画像摘要中，为 Agent 提供个性化上下文；但所有个性化判断均受合规、安全和隐私规则约束。

10 技术选型

本章说明“鱼你有图”项目的技术栈、选型理由和工程适配关系。选型原则是采用成熟、稳定、便于部署和便于团队维护的技术组合，使地图服务、空间数据、推荐模型、AI Agent、社区内容和用户数据能够形成统一的工程闭环。

10.1 技术栈总览

表 15: 技术栈总览

层次	技术选型	说明
前端框架	Vue 3 + Vite	构建移动端优先的单页应用，支撑地图、社区、记录、教程和个人中心等页面
UI 组件库	Element Plus + 图标组件	提供表单、弹窗、标签、按钮、图标等基础控件，保证页面风格统一
地图能力	高德 JS API 2.0 + 高德 Web Service	前端负责地图渲染，后端封装 POI、天气、地理编码等服务调用
后端框架	Python 3.11 + FastAPI + Pydantic 2	提供类型清晰的 RESTful API，适合规则推荐、AI Agent 和第三方服务封装
数据库	PostgreSQL + PostGIS	保存业务数据和空间数据，支撑附近查询、空间索引、禁钓区域判断和推荐排序
数据访问与迁移	SQLAlchemy 2 + Alembic	统一数据库模型、查询逻辑和表结构版本管理
缓存与会话	Redis	缓存天气、热点 POI、推荐结果、登录会话和限流计数
对象存储	OSS/S3 兼容对象存储	存放鱼获图片、帖子图片、头像、教程视频封面和报告长图
AI 服务	DeepSeek API	生成个性化出钓建议、推荐解释和复盘摘要，不直接决定排序
网关与部署	Nginx + HTTPS	托管前端静态资源，反向代理 /api，处理 HTTPS 和访问日志
测试与质量	Pytest + 前端构建检查	覆盖后端服务、数据模型、推荐规则、权限控制和前端构建质量

10.2 前端选型理由

前端采用 Vue 3 + Vite。Vue 组件模型清晰、学习成本适中、生态成熟，适合构建地图首页、钓点详情、社区信息流、发布表单、出钓记录、教程列表和个人报告等页面。Vite 提供快速构建和模块化开发能力，便于团队在页面交互、地图组件和 API 调用之间保持清晰边界。

Element Plus 用于基础控件和交互组件，能够减少重复开发，使页面风格、表单校验、弹窗交互和状态提示保持一致。地图类页面由高德 JS API 承接，普通业务页面由 Vue 组件承接，二者通过统一状态和 API 服务层协作。

10.3 后端选型理由

后端采用 FastAPI。FastAPI 与 Pydantic 结合后，可以直接定义 POI、记录、帖子、推荐、天气、用户偏好等模型，接口参数和响应结构清晰，适合投标文件、接口文档和代码实现保持一致。Python 生态对规则模型、统计分析、AI API 调用和数据处理友好，能够支撑推荐 Agent 的快速迭代。

后端分为 API 路由层、业务服务层、数据访问层和第三方服务封装层。API 路由层处理 HTTP 请求和参数校验；业务服务层承接推荐、记录、社区、报告和权限逻辑；数据访问层通过 SQLAlchemy 操作 PostgreSQL；第三方封装层统一接入高德、DeepSeek、对象存储和通知服务。

10.4 数据库选型理由

数据持久化采用 PostgreSQL + PostGIS。PostgreSQL 具备成熟的事务、索引、约束和备份能力，适合保存用户、记录、帖子、评论、活动、订单等关系明确的数据。PostGIS 提供空间类型、空间索引和空间函数，能够直接支撑附近钓点查询、禁钓区叠加判断、水域范围筛选和位置脱敏等 GIS 场景。

相比 MySQL，PostgreSQL + PostGIS 在空间数据处理方面更适合本项目；相比 MongoDB，关系型数据库更便于维护用户、记录、帖子、活动报名、互动数据之间的关联一致性。对于推荐结果、报告快照和第三方摘要等半结构化内容，PostgreSQL 的 jsonb 字段能够兼顾灵活性和查询能力。

10.5 AI 与推荐选型理由

推荐系统采用规则模型与 AI Agent 分工协作。规则模型负责可解释排序、合规拦截和风险降权，避免推荐结果不可验证；AI Agent 负责解释推荐原因、结合用户偏好生成出钓建议、形成复盘摘要和教程建议。该设计既能体现智能化服务能力，也能保证合规、安全和可审计。

DeepSeek API 用于自然语言生成。后端只向大模型传递结构化上下文和授权画像摘要，不传递完整隐私原文。大模型输出必须经过格式校验和风险约束，不允许直接覆盖规则排序结果。

10.6 部署与运维选型理由

Nginx 负责前端静态资源托管、HTTPS 终止、反向代理和访问日志。Redis 用于缓存热点数据、天气快照、推荐结果和限流计数，降低数据库和第三方服务压力。对象存储用于保存图片、视频、头像和报告长图，数据库仅保存文件元数据和访问地址。

Alembic 负责数据库迁移脚本管理，保证不同环境表结构一致；Pytest 用于后端单元测试和接口测试；前端构建检查用于保证页面资源可正常打包。通过这些技术组合，系统能够支撑课程交付、线上运行和生产部署。

11 第三方服务集成

本章说明平台第三方服务的接入方式、责任边界、密钥管理和降级策略。第三方能力主要用于地图底图、POI 检索、天气快照、对象存储、HTTPS 证书和 AI 解释生成。系统设计要求第三方服务由后端统一封装，前端只获取必要的展示配置和业务结果，避免 Web 服务 Key、AI Key 等敏感信息暴露在前端代码中。

11.1 高德地图服务

高德地图服务分为前端 JS API 和后端 Web Service 两类能力。

高德 JS API 2.0: 用于前端地图渲染、标记点展示、地图拖动缩放、关键字搜索体验和地图交互。首页地图、POI 标记、钓点详情入口和位置选择均基于该能力实现。前端加载地图所需配置通过 `/api/amap/config` 获取，不在页面中硬编码真实 Key。

高德 Web Service: 由后端封装，用于 POI 搜索、周边检索、天气查询、地理编码和逆地理编码。Web Service Key 只保存在服务端环境变量中，前端不得直接调用带密钥的 Web 服务接口。

表 16: 高德服务接入责任划分

能力	接入位置	设计说明
地图底图与标记渲染	前端	使用高德 JS API 2.0 渲染地图、POI 标记和交互状态
JS API 配置下发	后端	<code>/api/amap/config</code> 返回前端必要配置，便于环境隔离和集中管理
POI 周边检索	后端	后端调用高德 Web Service，并结合自建垂钓 POI 做语义增强
天气查询	后端	天气结果转换为统一 WeatherSnapshot，供推荐模型和页面摘要使用
地理编码与逆地理编码	后端	用于记录位置回填、城市识别、地址展示和位置隐私模糊表达

高德 POI 提供通用地图点位，平台在此基础上叠加鱼种、设施、规则、风险、用户记录和社区热度，形成垂钓语义 POI。高德结果不直接等同于官方可钓点，合规判断必须结合平台维护的规则字段和公开管理要求。

11.2 DeepSeek API

DeepSeek API 用于生成推荐解释、个性化出钓建议和复盘摘要。系统不把大模型作为排序器，也不让大模型生成未经校验的禁钓结论。DeepSeek 请求由后端统一封装，核心控制项如下：

- **密钥管理**：通过 DEEPSEEK_API_KEY 环境变量配置，不写入代码、不传给前端。
- **模型选择**：通过 DEEPSEEK_MODEL 控制，默认使用稳定的对话模型，便于统一替换和灰度发布。
- **超时控制**：后端调用设置超时时间，避免 AI 服务慢响应影响主流程。
- **输入控制**：只传规则推荐结果、候选 POI 摘要、天气摘要、用户意图和授权画像摘要，不传完整隐私数据。
- **输出控制**：要求返回结构化 JSON，前端只渲染指定字段，并由后端进行格式校验。

11.3 天气与环境数据服务

天气数据通过后端统一接口获取和标准化，不让业务层直接依赖第三方返回结构。天气字段包括城市、天气现象、温度、体感温度、风向、风力、湿度、气压、能见度、预警信息和更新时间。

推荐模型使用天气数据时只做适宜度判断，不输出“必定爆护”等不可验证表述。遇到雷雨、大风、台风、暴雨等风险天气时，系统优先提示安全风险，并在推荐排序中降低户外野钓点位优先级。

11.4 对象存储与 CDN

鱼获图片、帖子图片、用户头像、教程视频封面和报告长图存放在对象存储中，并通过 CDN 加速访问。数据库只保存文件 URL、文件类型、大小、归属用户、关联业务 ID 和审核状态，不直接存放大文件。

对象存储集成策略如下：

- 上传由后端生成受控上传地址或统一代理上传，限制文件类型、大小和数量。
- 私密记录图片不直接公开访问，需结合权限校验或短期签名 URL。
- 删除帖子或记录时，业务数据先软删除，文件清理由异步任务处理，避免误删。
- 图片访问地址与审核状态绑定，未通过审核的图片不进入公开社区流。

11.5 HTTPS、域名与证书

平台通过 HTTPS 提供服务，避免用户位置、登录凭证、发帖内容和图片上传信息在传输过程中被窃听或篡改。Nginx 负责 HTTPS 终止、证书自动续期、静态资源托管、访问日志和 /api 反向代理。

11.6 服务降级策略

第三方服务不可用时，系统应保持核心流程可访问。降级策略如下：

表 17: 第三方服务降级策略

服务	异常场景	降级方案
高德 JS API	地图加载失败、Key 配置错误	前端展示钓点列表和错误提示，不影响查看 POI 文本信息
高德 POI 服务	周边搜索失败或超时	使用平台自建 POI 和缓存数据，提示用户稍后刷新地图结果
天气服务	天气接口失败	使用最近一次天气快照或展示天气未知，推荐模型降低天气因子权重
DeepSeek API	超时、限额、异常	返回规则模型解释模板，推荐排序结果不受影响
对象存储/CDN	图片上传或访问失败	保留文本记录和帖子，图片显示占位图，后台重试上传

通过以上设计，第三方服务增强用户体验，但不成为核心业务闭环的单点故障。

12 安全、隐私与合规

本章说明平台在数据安全、位置隐私、用户鉴权、内容治理和垂钓合规方面的设计。由于“鱼你有图”涉及用户位置、出钓记录、图片内容、社区互动、第三方 API Key 和个性化推荐画像，安全设计必须贯穿前端、后端、数据库、第三方调用和运维部署全过程。

12.1 数据安全

平台采用“密钥集中管理、传输加密、最小权限、可备份恢复”的数据安全策略。

- **密钥管理：**高德 Web Service Key、DeepSeek Key、数据库密码、对象存储密钥均通过环境变量或密钥管理服务配置，不写入代码仓库、不出现在前端构建产物中。
- **传输安全：**平台统一使用 HTTPS；Nginx 负责证书配置和安全头设置，后端只接受可信网关转发的请求。
- **存储安全：**业务数据进入 PostgreSQL，数据库账号按环境和权限拆分；对象存储文件按公开、私密、审核中等状态控制访问。
- **备份恢复：**数据库每日增量备份、每周全量备份；对象存储开启版本管理或回收机制；上线前完成恢复演练。
- **日志脱敏：**日志记录接口路径、耗时、状态码和错误摘要，不记录完整密钥、明文密码、完整精确坐标和大模型原始隐私输入。

后端通过统一配置模块读取高德、DeepSeek、数据库和对象存储配置；前端 API 调用集中在服务层，便于统一追加鉴权头、错误处理、重试策略和权限提示。

12.2 位置隐私保护

垂钓位置具有明显隐私属性。精确钓点如果被无控制公开，可能造成个人隐私泄露、点位拥挤、环境破坏和合规风险。因此平台对位置展示采用分级控制。

表 18: 位置隐私分级设计

级别	展示方式	适用场景
精确位置	展示具体 POI 或坐标附近位置	用户主动公开的商业钓场、公开水域或教程练习点
水域模糊	展示水域、片区或 1-3 km 偏移后的范围	普通鱼获分享，既提供参考又避免暴露钓位
仅城市	仅展示城市或区县	用户希望分享鱼获但不暴露具体位置
完全隐藏	不展示位置字段	私密记录、敏感水域、用户未授权发布位置

前端发布页面提供内容可见性和位置可见性选择；后端返回帖子和记录时再次执行脱敏，不能只依赖前端隐藏。数据库中同时保存原始坐标和展示坐标，原始坐标仅用于本人记录、统计和推荐计算，展示坐标按权限生成。

12.3 用户鉴权与权限控制

平台采用统一鉴权机制，可通过手机号、微信授权或账号密码登录，由服务端签发访问令牌。后端所有写接口必须校验请求发起用户身份，避免越权操作。

权限控制要求如下：

- 用户只能修改和删除自己的出钓记录、帖子、评论、学习进度和订单。
- 管理员接口与普通用户接口隔离，管理员操作记录审计日志。
- 私密记录默认仅本人可见，生成社区帖子时需用户主动确认可见性。
- 活动报名、取消报名、签到等状态变更接口需校验用户身份和活动状态。
- AI 接口不接受任意用户传入内部系统提示词，不返回后端配置和调试信息。

接口采用 401/403 明确区分“未登录”和“无权限”，并在前端进行登录态失效提示。

12.4 个性化数据授权

个性化推荐依赖用户偏好和垂钓行为数据。平台必须在用户授权范围内使用相关数据，并允许用户关闭个性化服务或清除画像摘要。

授权控制包括：

- 用户可设置是否允许使用出钓记录、收藏、浏览和教程学习记录优化推荐。

- Agent 只读取授权画像摘要，不直接暴露完整私密记录和精确坐标。
- 个性化推荐输出需说明主要依据，例如目标鱼种、偏好钓法、可接受距离或历史效率指标。
- 用户撤回授权后，系统停止使用其行为数据生成个性化推荐，并按策略清理或冻结画像摘要。

12.5 接口与业务风控

平台应对高频调用、恶意发布和异常写入设置基础风控：

- 对登录、发布、评论、点赞、AI 解释、地图搜索等接口设置频率限制。
- 对帖子、评论和私信内容进行敏感词、广告、违法内容和人身攻击检测。
- 对图片上传限制格式、大小和数量，并接入图片审核能力。
- 对第三方 API 调用设置超时、重试上限和熔断，避免外部服务异常拖垮后端。
- 对数据写入接口进行 Pydantic 参数校验和数据库约束校验，防止非法字段和明显异常值进入业务数据。

数据库层增加非空约束、外键约束、枚举状态、唯一索引和必要的软删除字段。核心写操作记录审计日志，便于问题追踪和责任定位。

12.6 合规性设计

平台合规设计主要围绕个人信息保护、位置数据保护、垂钓规则提示和用户内容治理展开。

个人信息保护：平台仅收集实现功能所需的数据，例如昵称、头像、城市、出钓记录、帖子内容、用户偏好和用户主动填写的鱼获信息。对于精确位置、图片、私信和个性化画像等敏感数据，提供明确授权、可撤回和可删除机制。用户删除记录或帖子后，前端不再展示，后端进入软删除或清理流程。

位置数据保护：精确坐标不默认公开。社区内容对外展示时，根据用户选择和后端权限规则输出精确、水域模糊、仅城市或隐藏位置。平台不得将用户私密钓点用于公开推荐，除非用户明确授权并经过脱敏处理。

禁钓与规则提示：系统根据公开公告、人工维护规则、水域管理要求和平台风险标签提供合规提醒。规则数据保存来源、发布时间、有效期和适用范围。页面提示用户以当地最新公告和现场管理要求为准，避免把平台建议表述为执法或审批结论。

用户内容治理：社区帖子、评论、私信、活动群消息支持举报、隐藏、删除和审核状态。对于违法违规内容、广告引流、侵犯他人隐私、公开敏感钓点、破坏生态环境的内容，平台提供处理机制。

12.7 安全验收要点

安全验收不只检查功能是否可用，还应检查以下项目：

1. 前端代码和构建产物中不存在高德 Web Service Key、DeepSeek Key、数据库密码等敏感信息。
2. 发布帖子选择“模糊”或“隐藏”位置后，接口返回结果不包含可直接还原的精确坐标。
3. 未登录或非本人用户不能修改、删除他人的记录和帖子。
4. 第三方服务不可用时，系统返回可理解的错误或降级内容，不泄露堆栈。
5. 日志中不记录明文密钥、完整精确位置和用户隐私原文。
6. 备份文件、测试账号和初始化数据不包含真实个人敏感信息。

通过上述措施，平台能够在地图、记录、社区、推荐和 AI 服务之间建立清晰的安全边界，满足课程项目技术投标文件对数据安全、隐私保护和合规设计的要求。